

DAI HOC QUOC GIA THANH PHO HO CHI MINH
TRUONG DAI HOC KHOA HOC TU NHIE
KHOA TOAN — TIN HOC

BAO CAO THUC HANH

Lab04: PHP Secure Forms, PRG, Anti-spam & Session
Login

Ung dung: WorkshopHub — Mini Workshop Registration Portal

Giang vien huong dan:	TS. Tran Anh Tuan
Mon hoc:	Lap trinh Web
Sinh vien thuc hien:	Le Pham Hong Hien
MSSV:	22110059

TP. Ho Chi Minh, Thang 6/2026

Mục lục

1	Cau 1: Xây dựng ứng dụng WorkshopHub	2
1.1	Giới thiệu bài toán	2
1.2	Kiểm tra môi trường	2
1.3	Cấu trúc dự án	2
1.4	Cấu hình PSR-4 Autoload	3
1.5	Front Controller — <code>public/index.php</code>	3
1.6	Router — phân biệt 404 và 405	5
1.7	Cấu hình Session an toàn	5
1.8	Helpers — <code>escape</code> , <code>flash</code> , <code>old input</code> , <code>require_login</code>	6
1.9	Form bảo mật và Validation server-side	7
1.10	PRG và Flash message	9
1.11	Anti-spam — Honeypot và Rate limit	9
1.12	Login flow — <code>regenerate id</code> , <code>logout sạch</code> , <code>timeout</code>	9
1.13	Bảng dinh tuyến	12
1.14	Tóm tắt yêu cầu đã thực hiện (Cau 1)	14
2	Bài kiểm tra nhỏ (T01–T16)	15
3	Cau 2: Problem Solving	18
3.1	Vì sao server-side validation là bắt buộc?	18
3.2	Vì sao phải phân biệt GET và POST?	18
3.3	PRG giải quyết vấn đề gì?	18
3.4	Validation và anti-spam khác nhau thế nào?	18
3.5	Honeypot có giới hạn gì?	18
3.6	Rate limit bằng session có ưu/nhược gì?	19
3.7	Vì sao <code>session_set_cookie_params()</code> phải chạy trước <code>session_start()</code> ?	19
3.8	Vì sao login thành công phải <code>session_regenerate_id(true)</code> ?	19
3.9	Logout sạch nghĩa là gì?	19
3.10	Flash message giúp tránh "trạng thái" thế nào?	19
3.11	Remember me có rủi ro gì?	20
3.12	Nếu mô phỏng thành dự án thật, nên cải tiến phần nào?	20
4	Kết luận	21

1 Cau 1: Xay dung ung dung WorkshopHub

1.1 Gioi thieu bai toan

Em chon huong **Mini Workshop Registration Portal** — dat ten la **WorkshopHub**. Day la cong dang ky tham du workshop danh cho khach tham quan, kem khu vuc **dang nhap + bang dieu khien** danh rieng cho nhan vien quan ly. Resource (tai nguyen) chinh la **registration**.

WorkshopHub cho phep:

- Khach xem trang chu gioi thieu (GET /).
- Xem danh sach cac luot dang ky kem trang thai (GET /registrations).
- Dien form dang ky (GET /registrations/create) va gui (POST /registrations).
- Nhan vien dang nhap (GET/POST /login), xem dashboard (GET /dashboard), xem thong tin phien (GET /session-demo) va dang xuat (POST /logout).

So voi bai mau *Student Consultation*, em da doi toan bo ngu canh nghiep vu: ten project, ten resource (**registration**), ten controller/route/view/file JSON, danh sach in-list (chu de workshop, ca tham du), thong bao va du lieu mau.

Trong tam Lab04 la **flow bao mat form va session**: doc input an toan, validation server-side, PRG, chong spam (honeypot + rate limit), dang nhap voi **password_hash/password_verify**, **session_regenerate_id**, idle timeout va logout sach. Du lieu luu bang **file JSON** trong **storage/** (Lab04 khong dung database).

1.2 Kiem tra moi truong

- **PHP**: 8.2.12 (cli) — kiem tra bang `php -v`.
- **Composer**: may cham khong co Composer global, nen em copy thu muc **vendor/** (da co **ClassLoader** PSR-4) va sua thu cong **autoload_psr4.php**, **autoload_static.php** de map namespace **WorkshopHub** sang **src/** — dung ket qua ma `composer dump-autoload` sinh ra.
- **Git**: quan ly source code, push len GitHub.
- **IDE**: Visual Studio Code.
- **Chay**: `php -S 127.0.0.1:8104 -t public` tu trong **WorkshopHub/**.

1.3 Cau truc du an

```
WorkshopHub/
|-- composer.json          # PSR-4: "WorkshopHub\\" => "src/"
|-- vendor/               # Autoloader (commit kem, khong can composer)
|-- public/
|   |-- index.php         # Front Controller (entry point duy nhat)
|   '-- assets/css/style.css # CSS responsive
|-- src/
|   |-- Router.php        # Map METHOD+PATH; phan biet 404/405
|   |-- Response.php      # html/json/redirect/view + render layout
|   |-- Support/
|       |-- helpers.php   # h, redirect, flash, old, is_logged_in, require_lo
|       |-- Session.php   # cookie params, regenerate, logout_clean, timeout
|       |-- Storage.php   # doc/ghi file JSON
```

```

|   |   '-- Validator.php           # required/email/phone/length/in-list
|   '-- Controllers/
|       |-- HomeController.php       # GET /
|       |-- RegistrationController.php # GET/POST /registrations(+/create)
|       |-- AuthController.php       # GET/POST /login, POST /logout
|       |-- DashboardController.php   # GET /dashboard, GET /session-demo
|       '-- HealthController.php      # GET /health (lam them)
|-- views/
|   |-- layout.php                   # layout chung + navbar + flash UI
|   |-- home.php
|   |-- registrations/               # index.php, create.php
|   |-- auth/login.php
|   |-- dashboard.php, session-demo.php
|   '-- errors/                      # 404.php, 405.php
'-- storage/
    |-- users.json                   # tai khoan demo (bcrypt hash)
    '-- registrations.json           # du lieu mau

```

1.4 Cau hinh PSR-4 Autoload

Listing 1: composer.json

```

{
    "name": "workshophub/mini-workshop-registration-portal",
    "autoload": {
        "psr-4": { "WorkshopHub\\": "src/" }
    },
    "require": { "php": ">=8.0" }
}

```

Vi khong co Composer global, em sua truc tiep file autoload (dung ket qua cua composer dump-autoload):

Listing 2: vendor/composer/autoload_psr4.php

```

return array(
    'WorkshopHub\\' => array($baseDir . '/src'),
);

```

PHP se tu tim class WorkshopHub\Router tai src/Router.php, WorkshopHub\Controllers\Registr tai src/Controllers/RegistrationController.php.

1.5 Front Controller — public/index.php

Moi request deu di qua public/index.php. File nay (1) phuc vu file tinh, (2) cau hinh session cookie params **truoc** session_start(), (3) load autoloader + helpers, (4) khai tao Router + khai bao route, (5) dispatch.

Listing 3: public/index.php (rut gon)

```

// 1. PHP built-in server: tra file tinh truc tiep.

```

```

$uri = parse_url($_SERVER['REQUEST_URI'], PHP_URL_PATH);
if ($uri !== '/' && file_exists(__DIR__ . $uri) && !is_dir(
    __DIR__ . $uri)) {
    return false;
}
// 2. Autoloader + helpers.
require_once __DIR__ . '/../vendor/autoload.php';
require_once __DIR__ . '/../src/Support/helpers.php';

use WorkshopHub\Router;
use WorkshopHub\Support\Session;
use WorkshopHub\Controllers\{HomeController, HealthController,
    RegistrationController, AuthController, DashboardController
};

// 3. Cấu hình cookie flags TRUOC session_start() (bên trong
    Session::start()).
Session::start();

// 4. Router + Controllers + Routes.
$router = new Router();
$home = new HomeController(); $registration = new
    RegistrationController();
$auth = new AuthController(); $dashboard = new Dashboard
    Controller();
$health = new HealthController();

$router->get('/', [$home, 'index']);
$router->get('/registrations', [$registration, 'index'])
    ;
$router->get('/registrations/create', [$registration, 'create'
    ]);
$router->post('/registrations', [$registration, 'store'])
    ;
$router->get('/login', [$auth, 'loginForm']);
$router->post('/login', [$auth, 'handleLogin']);
$router->post('/logout', [$auth, 'logout']);
$router->get('/dashboard', [$dashboard, 'index']);
$router->get('/session-demo', [$dashboard, 'sessionDemo
    ']);
$router->get('/health', [$health, 'check']);

// 5. Dispatch.
$router->dispatch($_SERVER['REQUEST_METHOD'],
    parse_url($_SERVER['REQUEST_URI'], PHP_URL_PATH));

```

[Anh chụp màn hình] Toàn bộ route khai báo tập trung tại public/index.php

1.6 Router — phân biệt 404 và 405

Listing 4: src/Router.php — dispatch()

```
public function dispatch(string $requestMethod, string
    $requestPath): void
{
    $requestMethod = strtoupper($requestMethod);
    $requestPath   = $this->normalize($requestPath);

    // Bước 1: khớp cả method lẫn path -> gọi handler.
    foreach ($this->routes as $route) {
        if ($route['method'] === $requestMethod && $route['path
            ']' === $requestPath) {
            call_user_func($route['handler']);
            return;
        }
    }

    // Bước 2: path tồn tại nhưng sai method -> 405 + Allow.
    $allowed = [];
    foreach ($this->routes as $route) {
        if ($route['path'] === $requestPath) { $allowed[] =
            $route['method']; }
    }
    if (!empty($allowed)) {
        Response::methodNotAllowed(array_values(array_unique(
            $allowed)));
        return;
    }

    // Bước 3: không khớp path nào -> 404.
    Response::notFound($requestPath);
}
```

1.7 Cấu hình Session an toàn

Điểm cốt lõi: `session_set_cookie_params()` phải gọi **trước** `session_start()`. Cookie dat HttpOnly, SameSite=Lax, con Secure bat theo moi truong (HTTPS).

Listing 5: src/Support/Session.php — start()

```
public static function start(): void
{
    if (session_status() === PHP_SESSION_ACTIVE) { return; }
```

```

$isHttps = (!empty($_SERVER['HTTPS']) && $_SERVER['HTTPS']
    !== 'off')
    || (($_SERVER['SERVER_PORT'] ?? null) == 443);

session_set_cookie_params([
    'lifetime' => 0,           // cookie phien
    'path'     => '/',
    'secure'   => $isHttps,    // theo moi truong
    'httponly' => true,        // JS khong doc duoc -> chong
                             XSS doc session
    'samesite' => 'Lax',       // chong CSRF co ban
]);
session_name('WSHSESSID');
session_start();
}

```

Bang chung that (header Set-Cookie khi dang nhap, chay HTTP local):

```
Set-Cookie: WSHSESSID=...; path=/; HttpOnly; SameSite=Lax
```

Secure vang mat dung nhu mong doi vi dang chay HTTP localhost.

1.8 Helpers — escape, flash, old input, require_login

Listing 6: src/Support/helpers.php (trich)

```

function h(?string $value): string {
    return htmlspecialchars((string)$value, ENT_QUOTES |
        ENT_SUBSTITUTE, 'UTF-8');
}

function redirect(string $url, int $code = 303): void {
    Response::redirect($url, $code); exit;
}

function flash_set(string $type, string $msg): void { $_SESSION
    ['_flash'][$type] = $msg; }
function flash_get(string $type): ?string {           // doc xong
    xoa -> hien 1 lan
    if (!empty($_SESSION['_flash'][$type])) {
        $m = $_SESSION['_flash'][$type]; unset($_SESSION['_flash'][$type]); return $m;
    }
    return null;
}

function old(string $f, string $d=''): string { return
    $_SESSION['_old'][$f] ?? $d; }
function field_error(string $f): string { return $_SESSION['_errors'][$f] ?? ''; }

function require_login(): void {
    if (Session::checkIdleTimeout()) {                // het phien
        -> logout sach
    }
}

```

```

        Session::startFresh();
        flash_set('warning', 'Phien dang nhap da het han...');
        redirect('/login');
    }
    if (!is_logged_in()) {
        flash_set('error', 'Ban can dang nhap de truy cap khu
            vuc nay.');
        redirect('/login');
    }
}

```

1.9 Form bao mat va Validation server-side

Doc input luon dung ?? " va trim(); khong tin du lieu user. Validation gom: **required**, **email**, **phone** (^0\d{9}\$), **do dai** (min/max), **in-list** (chu de & ca tham du).

Listing 7: src/Support/Validator.php (trich)

```

public function email(string $f, string $label): self {
    $v = $this->value($f);
    if ($v !== '' && !filter_var($v, FILTER_VALIDATE_EMAIL))
        $this->add($f, "$label khong dung dinh dang email.");
    return $this;
}

public function phone(string $f, string $label): self {
    $v = $this->value($f);
    if ($v !== '' && !preg_match('/^0\d{9}$/', $v))
        $this->add($f, "$label phai gom 10 chu so va bat dau
            bang 0.");
    return $this;
}

public function inList(string $f, array $allowed, string $label
): self {
    $v = $this->value($f);
    if ($v !== '' && !in_array($v, $allowed, true))
        $this->add($f, "$label khong hop le.");
    return $this;
}

```

Khi validate that bai, em luu **old input + loi theo field** vao session roi redirect lai form de user sua — khong phai nhap lai tu dau. Moi gia tri in ra HTML deu qua h() de chong XSS.

WorkshopHub **Dang ky moi** [+ Dang ky](#)

Dang ky tham du Workshop

Dien thong tin ben duoi. Cac truong co dau * la bat buoc.

Ho ten *

Email *

So dien thoai *

Chu de workshop *

Ca tham du *

Ghi chu (tuy chon)

[Gui dang ky](#) [Huy](#)

Khu vuc nhan vien quan ly dang ky.

[Dang nhap](#)

Hình 1: Form dang ky tham du Workshop (GET /registrations/create)

WorkshopHub **Dang ky moi** [+ Dang ky](#)

× Vui longkiem tra lai cac thong tin con loi.

Dang ky tham du Workshop

Dien thong tin ben duoi. Cac truong co dau * la bat buoc.

Ho ten *

A

Ho ten phai co it nhat 2 ky tu.

Email *

bad-email

Email khong dung dinh dang email.

So dien thoai *

12

So dien thoai phai gom 10 chu so va bat dau bang 0.

Chu de workshop *

-- Chon chu de --

Chu de la bat buoc.

Ca tham du *

-- Chon ca --

Ca tham du la bat buoc.

Ghi chu (tuy chon)

[Gui dang ky](#) [Huy](#)

Khu vuc nhan vien quan ly dang ky.

[Dang nhap](#)

Hình 2: Form dang ky voi loi canh tung field va du lieu cu duoc giu lai

1.10 PRG va Flash message

Sau POST /registrations hop le, em luu JSON roi `redirect('/registrations')` voi ma **303 See Other** — **khong render truc tiep**. Nho vay khi user refresh trang danh sach (GET) se khong tao ban ghi trung. Flash success/error luu trong session, doc xong xoa nen chi hien dung mot lan.

Listing 8: src/Controllers/RegistrationController.php — ket thuc store()

```
$record = $this->storage()->insert([...]); // luu JSON
$_SESSION['_last_submit_at'] = time(); // moc cho rate
    limit
// PRG: POST thanh cong -> redirect GET, KHONG render truc tiep
.
flash_set('success', 'Dang ky thanh cong! Ma dang ky cua ban la
    #' . $record['id'] . '.');
redirect('/registrations');
```

1.11 Anti-spam — Honeypot va Rate limit

Listing 9: store() — honeypot + rate limit

```
$honeypot = trim($_POST['website'] ?? '');
// 1. Honeypot: field "website" an khoi nguoi dung; bot dien ->
    chan.
if ($honeypot !== '') {
    flash_set('error', 'Yeu cau bi tu choi (phat hien hanh vi
        bot).');
    redirect('/registrations');
}
// 2. Rate limit: khong cho gui thanh cong 2 lan trong 5 giay.
$last = $_SESSION['_last_submit_at'] ?? 0;
if ((time() - $last) < self::RATE_LIMIT_SECONDS) {
    flash_set('error', 'Ban gui qua nhanh. Vui long cho vai
        giay roi thu lai.');
    flash_keep_input($input, []);
    redirect('/registrations/create');
}
```

[Anh chup man hinh] Honeypot va rate limit chan request kem flash error

1.12 Login flow — regenerate id, logout sach, timeout

Dang nhap dung: goi `session_regenerate_id(true)` (chong session fixation) **truoc** khi luu `user_id`, `role`, `login_at`, `last_activity_at`.

Listing 10: src/Support/Session.php — login() & logoutClean()

```

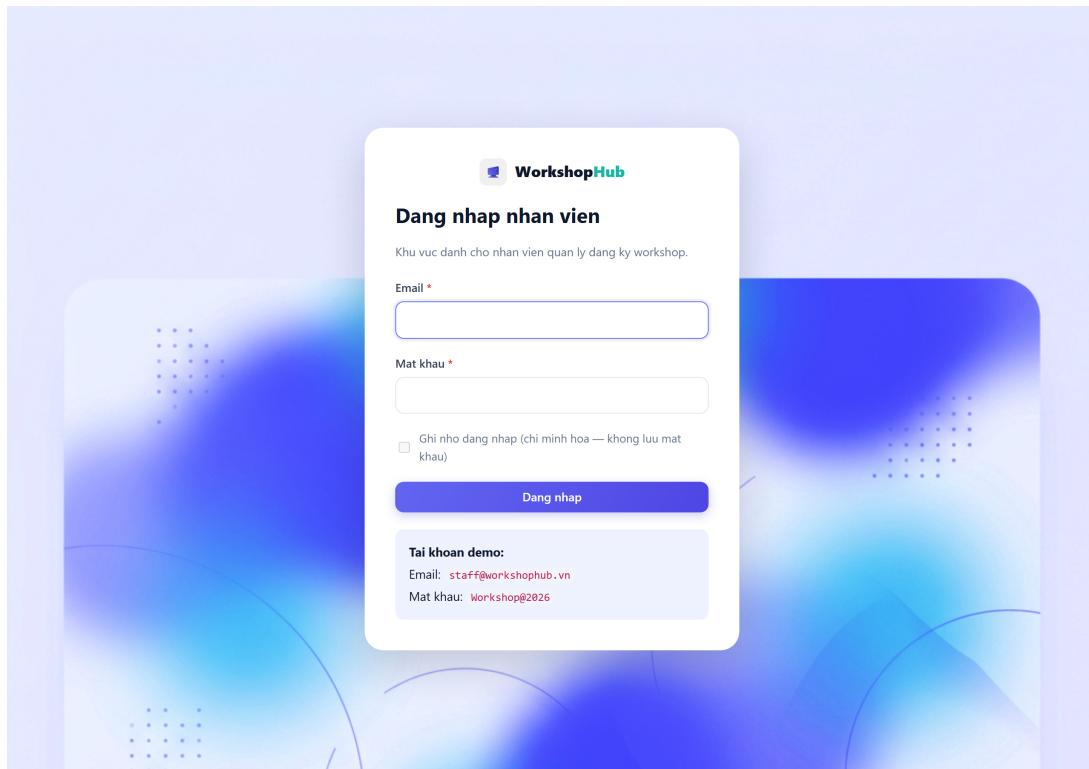
public static function login(array $user): void {
    session_regenerate_id(true);           // doi session
    id, xoa session cu
    $_SESSION['user_id']                    = $user['id'];
    $_SESSION['user_email']                 = $user['email'];
    $_SESSION['user_name']                  = $user['name'];
    $_SESSION['role']                       = $user['role'];
    $_SESSION['login_at']                   = time();
    $_SESSION['last_activity_at']           = time();
}

public static function logoutClean(): void {
    $_SESSION = [];                         // 1. xoa
    session data
    if (ini_get('session.use_cookies')) {    // 2. xoa
        cookie phien
        $p = session_get_cookie_params();
        setcookie(session_name(), '', [
            'expires' => time() - 42000, 'path' => $p['path'],
            'domain' => $p['domain'], 'secure' => $p['secure'],
            'httponly' => $p['httponly'], 'samesite' => $p['samesite'],
        ]);
    }
    if (session_status() === PHP_SESSION_ACTIVE) session_destroy(); // 3. destroy
}

```

Xác thực dùng `password_verify` với hash bcrypt seed sẵn trong `storage/users.json`. POST `/logout` gọi `logoutClean()` rồi `startFresh()` để gửi cookie hợp lệ mang flash success về `/login`. Idle timeout 900s (mặc định); hết hạn -> logout sạch + redirect `/login` kèm flash.

Ghi chú giao diện: bạn mới nhất làm mới toàn bộ giao diện theo phong cách admin hiện đại — sidebar điều hướng cố định bên trái (logo, mục active, thanh accent, khu vực người dùng và nút đăng xuất ghim dưới), topbar breadcrumb, thẻ góc 16px với độ bóng mềm, và drawer trượt đáp ứng ở màn hình $\leq 860\text{px}$; palette indigo #6366F1 + teal #14B8A6. Toàn bộ chức năng (routing, validation, PRG, anti-spam, login/logout) không thay đổi.



WorkshopHub

Dang nhap nhan vien

Khu vuc danh cho nhan vien quan ly dang ky workshop.

Email *

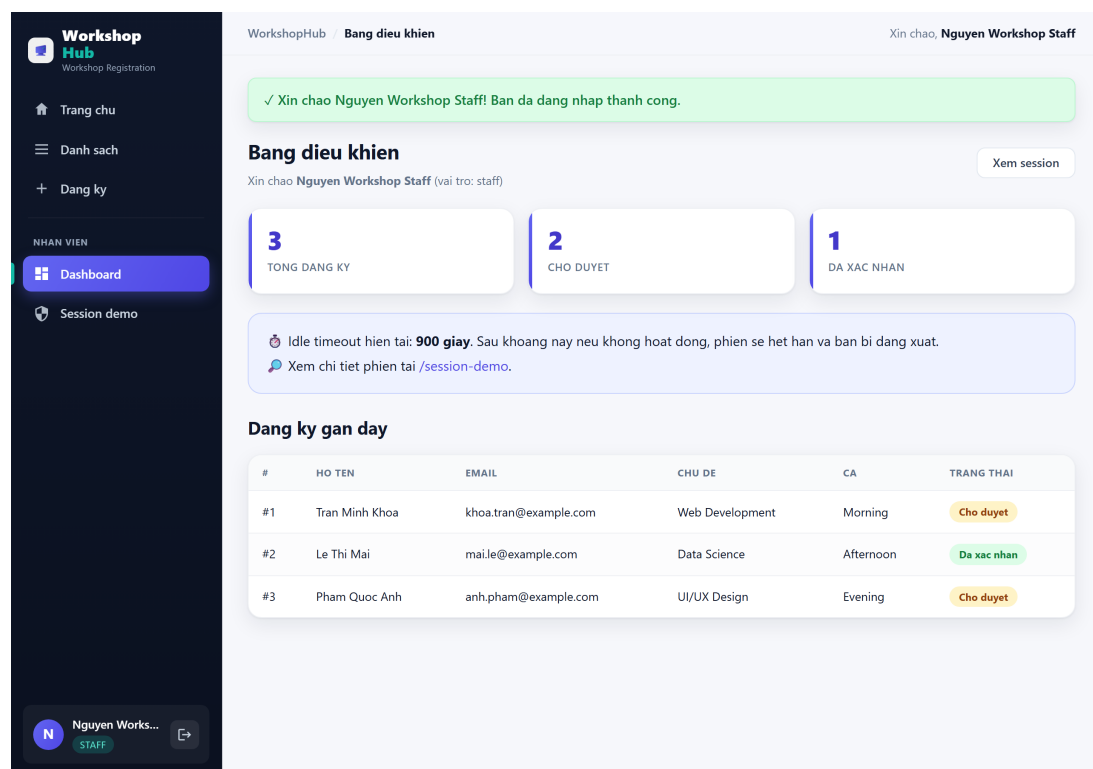
Mat khau *

☐ Ghi nho dang nhap (chi minh hoa — khong luu mat khau)

Dang nhap

Tai khoan demo:
Email: `staff@workshophub.vn`
Mat khau: `workshop@2026`

Hình 3: Form dang nhap nhan vien (GET /login)



WorkshopHub **Bang dieu khien** Xin chào, **Nguyen Workshop Staff**

✓ Xin chào Nguyen Workshop Staff! Bạn đã đăng nhập thành công.

Bang dieu khien
Xin chào Nguyen Workshop Staff (vai tro: staff) [Xem session](#)

3 TONG DANG KY

2 CHO DUYET

1 DA XAC NHAN

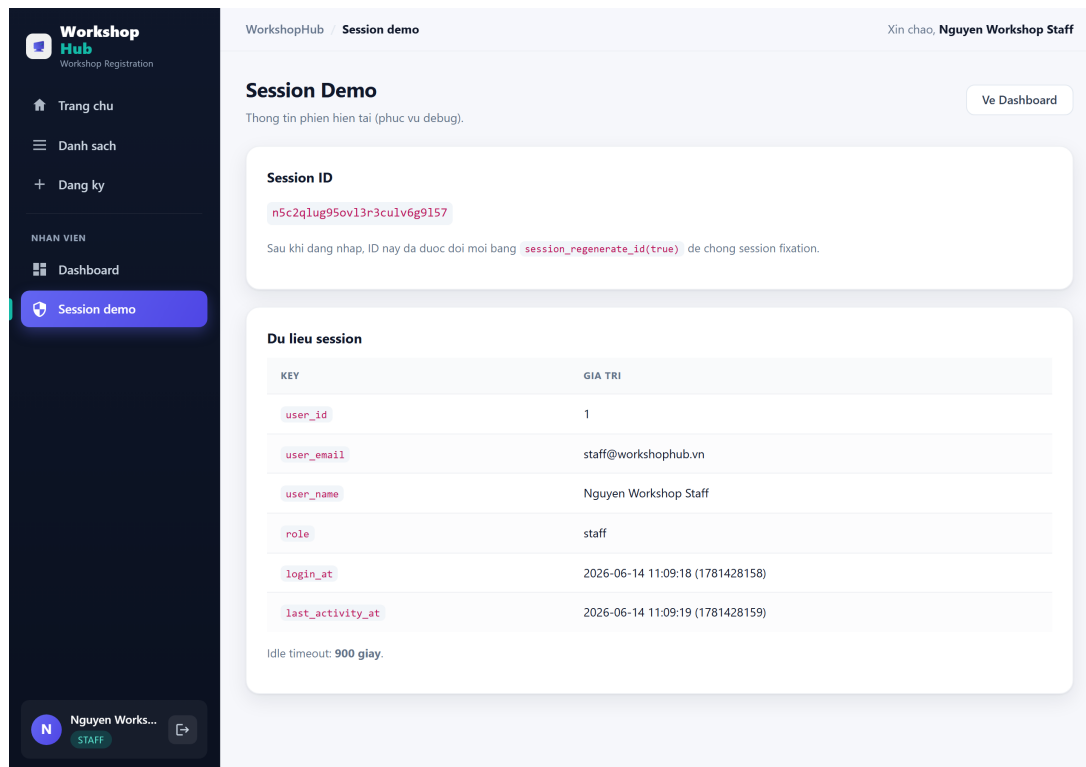
⌚ Idle timeout hien tai: **900 giay**. Sau khoang nay neu khong hoat dong, phien se het han va ban bi dang xuat.
🔗 Xem chi tiet phien tai [/session-demo](#).

Dang ky gan day

#	HO TEN	EMAIL	CHU DE	CA	TRANG THAI
#1	Tran Minh Khoa	khoa.tran@example.com	Web Development	Morning	Cho duyot
#2	Le Thi Mai	mai.le@example.com	Data Science	Afternoon	Da xac nhan
#3	Pham Quoc Anh	anh.pham@example.com	UI/UX Design	Evening	Cho duyot

Nguyen Works... STAFF

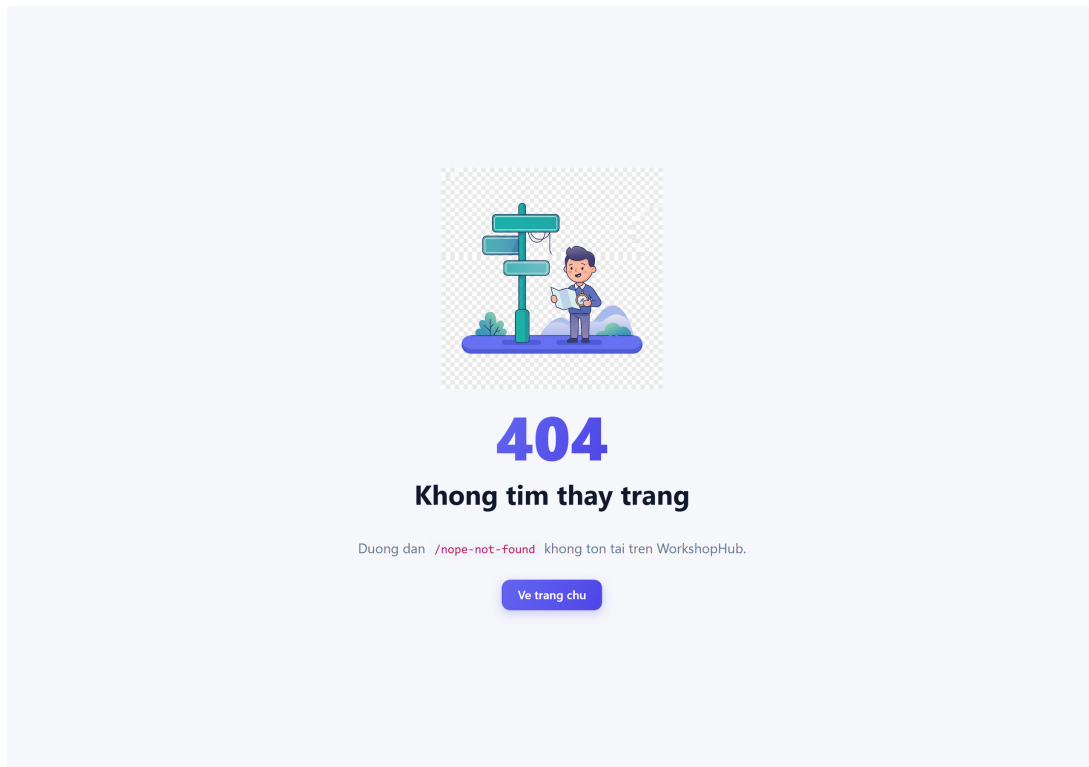
Hình 4: Dashboard sau khi dang nhap thanh cong (GET /dashboard) kèm flash success



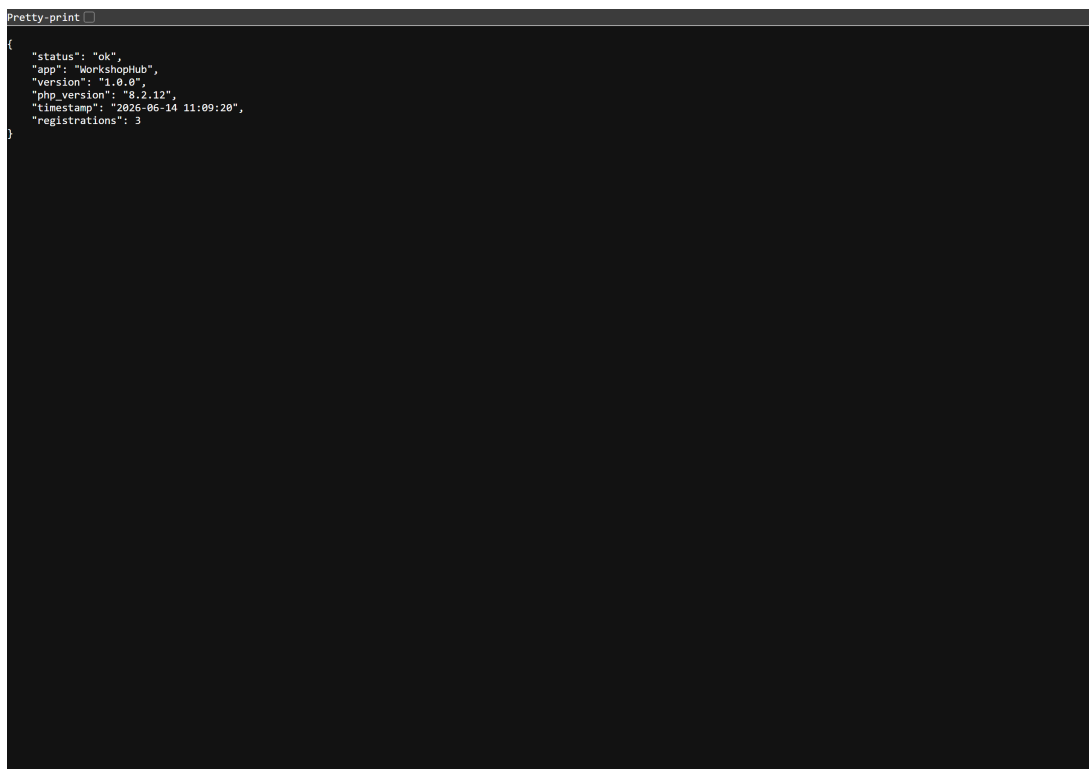
Hình 5: Trang session-demo hien session id moi sau regenerate (GET /session-demo)

1.13 Bảng dinh tuyen

Method	URL	Controller@Action
GET	/	HomeController@index
GET	/registrations	RegistrationController@index
GET	/registrations/create	RegistrationController@create
POST	/registrations	RegistrationController@store
GET	/login	AuthController@loginForm
POST	/login	AuthController@handleLogin
POST	/logout	AuthController@logout
GET	/dashboard	DashboardController@index
GET	/session-demo	DashboardController@sessionDemo
GET	/health	HealthController@check (lam them)
ANY	URL khong ton tai	Router -> 404
—	Route co that, sai method	Router -> 405 + Allow

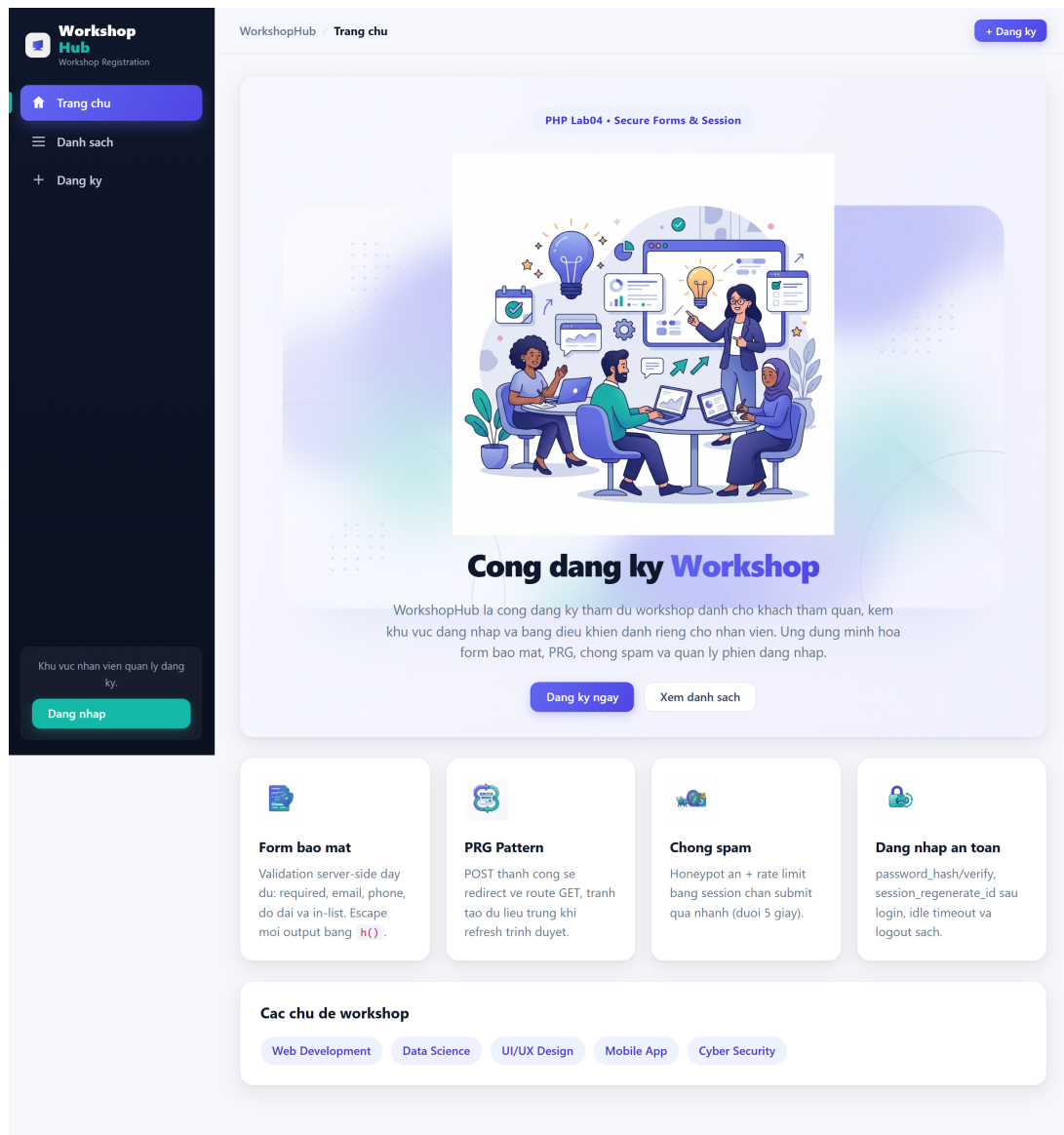


Hình 6: Trang 404 tùy biến khi truy cập URL không tồn tại (GET /nope-not-found)

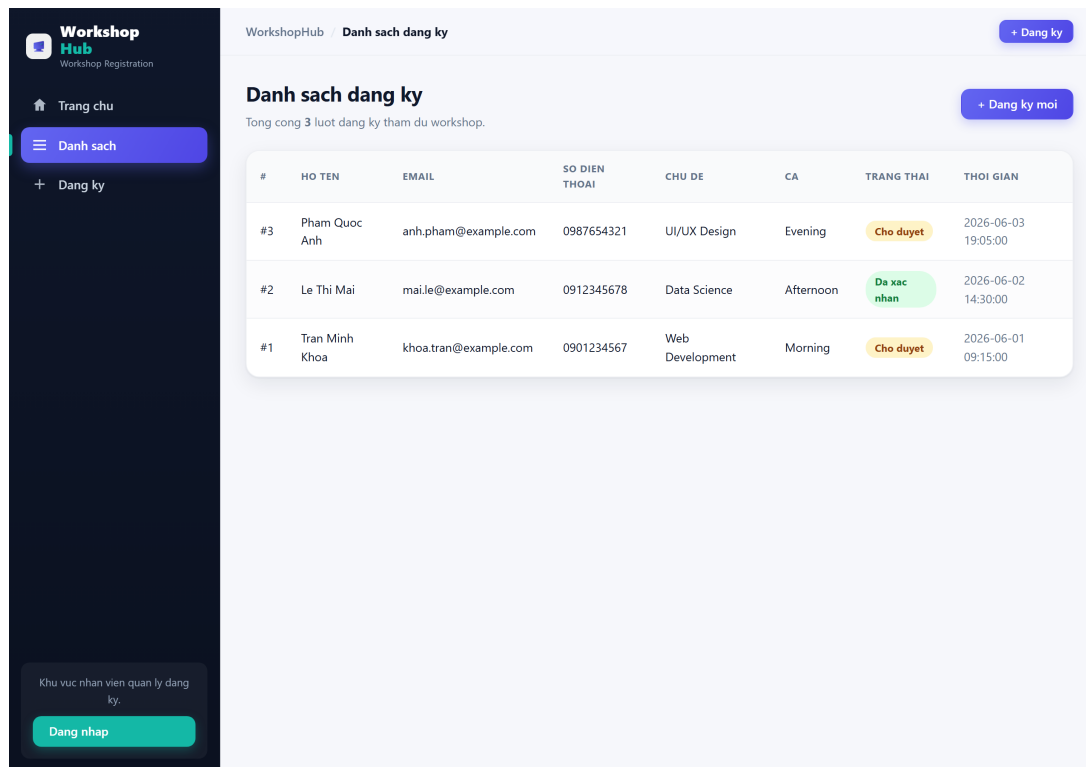


Hình 7: GET /health trả về JSON kiểm tra sức khỏe hệ thống (làm thêm)

1.14 Tóm tắt yêu cầu đã thực hiện (Câu 1)



Hình 8: Trang chủ WorkshopHub (GET /)



Hình 9: Danh sách đăng ký (GET /registrations)

2 Bài kiểm tra nhỏ (T01–T16)

Tất cả các mục dưới đây được kiểm tra bằng curl trên server 127.0.0.1:8104. Kết quả **that** được trích từ file `report/build-notes.md`.

Ma	Mục kiểm tra	Cách thực hiện	Kết quả thực tế	P/F
T01	GET/POST flow	Mô form bằng GET, submit bằng POST.	GET form 200; POST /registrations trả 303 (không render form trực tiếp).	✓
T02	Validation rỗng	Submit form rỗng.	303 về /create; hiện lỗi cảnh báo mọi field bắt buộc; không lưu JSON.	✓
T03	Validation định dạng	email=bad, phone=12, name=A, topic=Foo.	5 lỗi dung field (email, phone, họ tên, chủ đề, cá); records 4 -> 4.	✓
T04	Old input	Một số field dung, một số sai.	full_name/phone/topic giữ lại; chỉ email báo lỗi.	✓
T05	PRG chống refresh	Submit hợp lệ, xem dòng JSON, refresh GET list.	POST 303; records 3 -> 4; refresh GET vẫn 4 (không trung).	✓

Ma	Muc kiem tra	Cach thuc hien	Ket qua thuc te	P/F
T06	Flash mot lan	Sau submit, refresh list lan 2.	flash-success hien lan 1; refresh dem flash = 0.	✓
T07	Honeypot	Gui them field website co du lieu.	303 ve /registrations; flash error bot; records khong doi.	✓
T08	Rate limit	Gui thanh cong 2 lan trong duoi 5s.	Lan 1 luu (4->5); lan 2 bi chan, flash "gui qua nhanh"; van 5.	✓
T09	Escape output	Nhap <code><script>alert(1)</script></code>	Hien <code><script>alert(1)</script></code> ; so the script tho = 0.	✓
T10	Login sai	Sai mat khau demo.	303 ve /login; flash "Email hoac mat khau khong dung".	✓
T11	Login dung + regenerate	Login dung roi vao session-demo.	session id doi (j5ssp9... -> dqja7a...); dashboard 200.	✓
T12	Dashboard protection	Mo /dashboard chua dang nhap.	303 ve /login + flash yeu cau dang nhap.	✓
T13	Logout sach	Login, POST /logout, mo lai /dashboard.	Logout 303 ve /login (flash success); /dashboard 303 ve /login.	✓
T14	GET /logout	Truy cap /logout bang GET.	405 Method Not Allowed; header Allow: POST.	✓
T15	Timeout	Bat demo 10s, cho qua han, mo /dashboard.	303 ve /login; flash warning phien het han.	✓
T16	404/405	URL sai + sai method route co that.	/no-such 404; POST /registrations/create 405 (Allow: GET).	✓

Mot vai output curl that (trich):

```

POST /registrations (valid) -> 303 loc=/registrations ; Records
3 -> 4
Refresh GET /registrations -> 200 ; Records van = 4 (PRG OK)
flash-success refresh lan 2 -> 0 (hien dung 1 lan)

POST website=spam -> 303 ; flash: Yeu cau bi tu choi (phat hien
hanh vi bot)
submit2 trong 5s -> 303 ; flash: Ban gui qua nhanh...

Pre-login session id: j5ssp9gi70opb0r1t0dat7cvvr
Post-login session id: dqja7arsq2iaae3e8lr6iqu08sc (DA DOI)

GET /logout -> 405 ; Allow: POST

```

```
GET /no-such -> 404 ; POST /registrations/create -> 405 ; Allow  
: GET
```

3 Cau 2: Problem Solving

3.1 Vi sao server-side validation la bat buoc?

Client-side validation (HTML required, type=email) chỉ là tiền ich giao diện — người dùng có thể tắt JavaScript hoặc dùng curl/Postman gửi thành request, bỏ qua hết. Trong bài của em, nếu gửi POST /registrations bằng curl với email bad và phone 12 thì **server van bat loi**: Validator kiểm tra `filter_var(..., FILTER_VALIDATE_EMAIL)` và `preg_match('/^0\d{9}$/', $phone)`, trả 5 lỗi và không lưu JSON (records giữ nguyên 4). Ví dụ một field cụ thể: field phone có rule **required + phone pattern** — bắt buộc nhập, và phải gồm 10 chữ số bắt đầu bằng 0. Vì vậy client-side *không đủ* để bảo vệ dữ liệu; server mới là nơi quyết định.

3.2 Vi sao phải phân biệt GET và POST?

Trong bài của em: **GET** dùng cho hiển thị (/ , /registrations, /registrations/create, /login, /dashboard, /session-demo); **POST** dùng cho thay đổi trạng thái (/registrations tạo ban ghi, /login, /logout). Form tạo dữ liệu không nên dùng GET vì: thêm số hiển thị trong URL (lo thông tin), bị cache/bookmark và có thể **tạo dữ liệu trùng** khi reload hoặc khi crawler quét link. Logout nên dùng POST vì nó **thay đổi trạng thái server** (hủy phiên); nếu để GET, kẻ tấn công có thể nhúng `` để ép nạn nhân đăng xuất (một dạng CSRF). Bằng chứng: em chỉ khai báo POST /logout, nên GET /logout trả **405 + Allow: POST**.

3.3 PRG giải quyết vấn đề gì?

Nếu sau POST mà render kết quả trực tiếp, khi user nhấn **Refresh** trình duyệt sẽ hỏi "gửi lại form?" và lặp lại POST — tạo **ban ghi trùng**. Trong bài của em, `store()` sau khi lưu JSON sẽ `redirect('/registrations')` (303 See Other) — tức redirect về route **GET /registrations**. Em chứng minh bằng test T05: POST hop lên 4 records từ 3 lên 4; sau đó refresh GET danh sách nhiều lần, records **van la 4**, không phát sinh ban ghi mới.

3.4 Validation và anti-spam khác nhau thế nào?

Validation kiểm tra "**dữ liệu có đúng định dạng không**" (email hop lên, phone 10 số, chữ để nam trong danh sách). Anti-spam kiểm tra "**hành vi có đáng ngờ không**" (diện field bay, gửi quá nhanh). Một bot gửi đủ tên/email/phone hop lên thì **validation không chặn được** — vì dữ liệu vẫn "đúng". Khi đó honeypot (**website**) và rate limit (5 giây) của em giúp giảm rủi ro **gửi hàng loạt tự động và diện form bằng script**. Hai lớp này bổ trợ nhau: validation lo dữ liệu, anti-spam lo hành vi.

3.5 Honeypot có giới hạn gì?

Honeypot chỉ chặn **bot đơn giản** — loại diện mọi field trên form mà không phân biệt field an. Bot tinh vi có thể đọc CSS/JS, nhả ra **website** bị an (`position: absolute; left: -9999px`) và bỏ trống, hoặc chỉ gửi đúng các field thật. Nếu chạy thật, em đề xuất thêm: **CSRF token**, **CAPTCHA/reCAPTCHA**, rate limit theo **IP** ở tầng server (Nginx/WAF), kiểm tra thời gian diện form tối thiểu, và đánh điểm rủi ro hành vi.

3.6 Rate limit bang session co uu/nhuoc gi?

Uu: don gian, khong can store ngoai. Nhuoc: rate limit bang session **khong chan duoc** ke doi trinh duyét, xoa cookie, hoac dung nhieu phien — vi moi phien co `$_SESSION` riêng. Muon manh hon nen rate limit theo **IP, user, email**, hoac dung **server-side store** (Redis/DB) dem so request theo cua so thoi gian. Trong bai cua em, **5 giay** la hop ly cho demo: du de chan double-submit/refresh nhanh ma khong gay phien cho nguoi dung that.

3.7 Vi sao `session_set_cookie_params()` phai chay truoc `session_start()`?

`session_start()` la luc PHP gui header **Set-Cookie**. Neu set cookie params *sau* thi da muon — cookie phien da phat ra voi cau hinh mac dinh, cac co `HttpOnly/SameSite/Secure` khong duoc ap dung. Trong bai cua em, `Session::start()` goi `session_set_cookie_params(...)` ngay truoc `session_start()`. Y nghia cac co: **HttpOnly** — JavaScript khong doc duoc cookie (chong danh cap session qua XSS); **SameSite=Lax** — trinh duyét khong gui cookie trong request cross-site dang POST (chong CSRF co ban); **Secure** — chi gui cookie qua HTTPS. O local HTTP, **Secure nen tat** (em set theo `$isHttps`), vi neu bat thi trinh duyét se khong gui cookie tren HTTP va session se "mat".

3.8 Vi sao login thanh cong phai `session_regenerate_id(true)`?

Session fixation: ke tan cong ep nan nhan dung mot session id da biet (vi du qua link), roi sau khi nan nhan dang nhap, ke do dung lai chinh id ay de chiem phien. Truoc login session chi la "khach"(it tin cay); sau login no mang quyen nhan vien (rat tin cay). Doi id ngay khi nang quyen khien id cu (neu da bi lo) tro nen vo dung. Trong bai cua em, doan regenerate nam o `src/Support/Session.php`, ham `Session::login(): session_regenerate_id(true)`; goi **truoc** khi luu `user_id`. Test T11 cho thay session id doi tu `j5ssp9...` sang `dqja7a...` sau khi login.

3.9 Logout sach nghĩa là gì?

Chi `unset($_SESSION['user_id'])` la **chua du**: cac key khac (`role`, `login_at...`) van con, va cookie phien van ton tai tren trinh duyét — co the bi tai su dung. `logoutClean()` trong bai cua em xoa 3 thu: **(1)** toan bo `$_SESSION = []`; **(2)** cookie phien (`setcookie` voi expires qua khu); **(3)** `session_destroy()`. Sau logout, mo lai `/dashboard` phai bi **redirect ve /login** (test T13 xac nhan: dashboard tra 303 ve /login).

3.10 Flash message giúp tránh "ket trang thai"the nao?

Flash nen hien **mot lan roi bien mat** vi no la thong bao cho *ket qua vua xay ra*. Neu luu success/error trong session ma khong xoa, thong bao se **dinh mai** o moi trang — user thay "Dang ky thanh cong"hoai du khong con dang ky gi (UI bi "ket"). Trong bai cua em, flash duoc **set** trong controller (`flash_set('success', ...)` sau khi luu JSON) va **doc** trong `views/layout.php` qua `flash_get()` — ham nay doc xong **unset** ngay. Test T06 xac nhan: refresh list lan 2, so `flash-success = 0`.

3.11 Remember me co rui ro gi?

Tuyet doi **khong luu password trong cookie** — cookie de bi doc (neu khong HttpOnly), bi danh cap qua XSS/MITM, va luu plaintext la tham hoa. Remember me dung phai dung **token ngau nhien rieng**: server luu **hash cua token** (khong luu token tho), cookie chi giu token; co **co che thu hoi** (xoa token khi logout/doi mat khau, gan thiet bi, het han). Trong Lab04, checkbox remember me cua em **chi de thao luan** — em da **disable** no tren form login va ghi chu ro "chi minh hoa, khong luu mat khau".

3.12 Neu mo rong thanh du an that, nen cai tien phan nao?

1. **Chuyen JSON sang database (MySQL/PDO)**: nen, vi file JSON khong chiu duoc truy van dong thoi lon, kho tim kiem/loc/phần trang va de hong khi ghi chong. DB cho index, transaction, rang buoc toan ven.
2. **Them CSRF token** cho moi form POST: /registrations, /login, /logout — chong gia mao request.
3. **Logging & middleware**: ghi log request (method, path, status, IP), middleware kiem tra dang nhap/quyen truoc controller.
4. **Role-based access**: phan quyen **staff/admin**; validation nang cao (unique email, chong trung dang ky).
5. **Lien he tuan sau**: database/PDO/CRUD/MVC se giup thay storage JSON, tach Model ra khoi Controller, va lam CRUD day du cho **registration**.

4 Ket luan

Qua Lab04, em da xay dung WorkshopHub — mot cong dang ky workshop hoan chinh va hieu sau ve flow bao mat form/session:

- Doc input an toan, **validation server-side** day du (required, email, phone, do dai, in-list), loi dung field va giu old input.
- **PRG** (redirect 303) chong submit trung; **flash** hien dung mot lan.
- **Anti-spam**: honeypot + rate limit bang session.
- Cau hinh **session cookie** an toan truoc `session_start()`; **regenerate id** chong fixation; **idle timeout** + **logout sach**.
- Router phan biet ro **404** va **405** (kem header **Allow**).
- Toan bo 16 baikiem tra T01–T16 deu **Pass**,kiem chung bang `curl`.

Diem noi bat (lam them so voi yeu cau toi thieu):

- GET `/health` tra JSON kiem tra suc khoe (so route, so dang ky, phien ban PHP).
- Co che **demo timeout** (file `storage/.demo_timeout` hoac env `WSH_DEMO_TIMEOUT`) de rut idle timeout con 10s, thuan tien quay video/test.
- Mat khau luu bang **bcrypt** (`password_hash/verify`), khong luu plaintext.
- Giao dien **responsive**, nhat quan, co badge trang thai va flash UI.
- Kiem thu **ngoai browser** bang `curl` day du, ghi lai output that.
- README chi tiet + file du lieu mau JSON sach.

Bang doi chieu yeu cau (coverage)

Yeu cau bat buoc	Trang thai
Front Controller + Router + Controller tach nhom	✓
404 / 405 phan biet ro (+ header Allow)	✓
PSR-4 autoload (WorkshopHub\ => src/)	✓
Doc input an toan (?? + trim)	✓
Validation: required, email, phone, length, in-list	✓
Field errors + giu old input	✓
Escape output bang h()/htmlspecialchars	✓
PRG (POST -> redirect GET 303)	✓
Flash message hien dung mot lan	✓
Luu du lieu file JSON (storage/)	✓
Honeypot (field website)	✓
Rate limit bang session (5 giay)	✓
Session cookie flags truoc session_start()	✓
Login: password_verify + session_regenerate_id(true)	✓
Luu user_id, role, login_at, last_activity_at	✓
Dashboard protection (redirect /login + flash)	✓
Idle timeout -> logout sach + redirect	✓
Logout sach (clear data, destroy, xoa cookie) qua POST	✓
Remember me chi thao luan rui ro	✓
Baikiem tra T01–T16	✓
Problem Solving (12 nhom cau hoi)	✓
README + sample JSON + kiem tra bang curl (lam them)	✓
GitHub (https://github.com/lphhien112-gif/PHP-)	✓